

Security of Mobile Devices - Assignment 3

QR Code and Deep Link Hijacking in Android Applications

Team Composition (SAS1)

- BORSOS Matheas-Roland
- COMĂRLĂU Vlad-Constantin

Project Description

This project explores the attack surface of Android Intent resolution by combining offensive exploitation with defensive automated auditing. The core idea is to demonstrate how malicious QR codes and poorly configured deep links (Custom URI schemes and unverified App Links) can be weaponized to exploit implicit intent handling, and to provide a companion scanner that detects these vulnerabilities.

Motivation

Modern Android applications rely heavily on Inter-Process Communication (IPC) via implicit intents and deep linking for seamless UX and authentication (e.g., OAuth 2.0). Despite OS-level hardening like Android 12's Digital Asset Links, developers persistently use legacy custom URI schemes (scheme://callback). Because these schemes lack cryptographic origin verification, they introduce a critical attack surface called scheme collision.

If an application uses overly permissive intents without origin validation, attackers can register overlapping handlers to hijack the execution flow. This leads to severe vulnerabilities, including arbitrary intent injection and full account takeover via authorization token interception. This project combines offensive IPC exploitation with automated static auditing to expose their implicit trust and provide a mitigation strategy for securing the apps.

Goals

The Offensive Proof-of-Concept: Weaponizing QR codes and deep links to force a target app into executing unauthorized actions. This includes bypassing local authentication, hijacking OAuth tokens via implicit intents, and launching protected internal components via intent injection.

The Defensive Auditor: An automated static analysis tool that parses installed app manifests (AndroidManifest.xml) to flag insecure deep link configurations and overly permissive exported handlers.